

My Health @ EU
eHealth Digital Service Infrastructure
A service provided by the European Union

My Health @ EU
eHealth Digital Service Infrastructure
Electronic cross-border health services in the EU

eHealth DSI

Security Services Specification

DOCUMENT VERSION	10.0.0
DATE	01/06/2026
STATUS	Wave 10 Operation Ready

DG SANTE, CEF eHealth DSI, 2026
Reuse is authorised, provided the source is acknowledged.

COVER AND CONTROL PAGE OF DOCUMENT	
Document old name:	D3.7.2 FINAL SECURITY SERVICES SPECIFICATION
Document name:	Security Services Specification
Distribution level*:	PU
Status:	Wave 10 Operation Ready
Author(s): Organization:	eHealth DSI provider EU

* Distribution level: PU = Public, PP = Restricted to other programme participants, RE = Restricted to a group specified by the consortium, CO = Confidential, only for members of the consortium.

ABSTRACT
The goal of the Security Services is the definition of a security system ensuring confidentiality, integrity and availability of data on the basis of the functional service requirements and taking into account the existing level of security implemented in each country.

CHANGE HISTORY				
Version	Date	Status Changes	From	Description
V10.0.0	01/06/2026	Wave 10 Operation Ready: CP090-EUDI Wallet integration updates	eHealth DSI Solution Provider	
V10.0.0-RC	29/04/20236	Wave 10 Release Candidate: CP090-EUDI Wallet integration updates	eHealth DSI Solution Provider	
V7.0.0	18/07/2023	Wave 7 Operation Ready Administrative Update	eHealth DSI Solution Provider	
V7.0.0	05/06/2023	Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V6.1.0	29/07/2022	Wave 6 Operation Ready	eHealth DSI Solution Provider	• Review of the deprecated links
V6.0.0	21/04/2022	Wave 6 Release Candidate	eHealth DSI Solution	

			Provider	
V5.0.0	17/09/2020	Wave 5 Release Candidate	eHealth DSI Solution Provider	• Align Access Control with EU Legislation
V4.0.0	29/04/2020	Wave 4 Release Candidate	eHealth DSI Solution Provider	
V3.0.0	02/07/2019	Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V2.2.0	30/06/2018	Wave 2 Operation Ready	eHealth DSI Solution Provider	
V2.2.0	30/06/2018	Wave 2 Operation Ready	eHealth DSI Solution Provider	
V2.1.0	01/06/2017	Wave 1 Operation Ready – Released for eHMSEG adoption	eHealth DSI Solution Provider	
V2.0.0	28/03/2017		eHealth DSI provider	• Remove all references to epSOS and requirements
V0.8	29/10/2010		SEG members	• Updates

TABLE OF CONTENTS

1 The documents organisation and Contents 5
1.1 Contents of "Master document" 5
2 Introduction 5
2.1 Goals 5
2.2 Glossary & Abbreviations 6
3 Assumptions & Guidelines 6
3.1 Security View 6
3.1.1 Objectives prioritization 6
3.1.2 Indications for choice of security measures 7
3.2 Risk Analysis 7
4 Overall picture & logical scheme 7
4.1 Overall picture 8
4.2 eHealth DSI Security challenges 9
4.2.1 Security challenges 9
4.2.2 Security core concepts 10
4.3 Logical scheme 11
5 Definition of elements and actors relevant for security issues 12
5.1 Data classification 12
5.1.1 Classification of PID Claims During the Identification Transaction 14
5.1.2 Ephemeral Handling Requirement 15
5.2 Actors 15
5.2.1 Amendment to the Patient Actor 16
5.2.2 New Actor: EUDI Wallet PID Issuer 16
5.2.3 New Actor: NCP-B EUDI Relying Party 16
5.3 Actors from a security point of view 17
6 References 19
6.1 Normative References 19

1 The documents organisation and Contents

The process of the management of eHealth DSI Security is based on the principles as defined in [ISO/IEC TR 13335] (ISO/IEC 27000).

1.1 Contents of "Master document"

The Security Specifications contains by four separate documents, as follows:

1st document (this one, the master): the “Security Services Specification”;
2nd document: the “Security Policies”;
3rd document: the “Security Services”;
4th document: a “Congruity and Suitability analysis”.

The Master document describes the process of the management of eHealth DSI Security; the risk analysis carried out and the safeguards selected.

The second document provides the eHealth DSI high level Security Policy description.

The third document details the technical aspects of the security services implementing the selected NCP safeguard. These security services, together with the eHealth DSI Security requirements must be implemented by each country in order to establish the “circle of trust” for the interchange of the Citizen health-care data among the countries, according to the use cases.

The fourth document analyses the congruity and suitability of the eHealth DSI Security Services and Policies.

Going into details for this “master” document:
Chapter#2 (Introduction): describes the overall goals of this document.

Chapter#3 (Assumptions & guidelines): mainly describes the eHealth DSI security objectives; the strategies that have been adopted for the risk analysis of the eHealth DSI system, and the strategy for selection of the security measures.

Chapter#4 (Overall picture & logical scheme): describes the security environment, the security principles and highlights the boundary of the eHealth DSI system.

Chapter#5 (Definition of elements and actors relevant for security issues): describes the classification of the health-data, the Actors who operate on those data, the threats to the data and the related impacts.

2 Introduction

2.1 Goals

The goal of the Security Services Specification is the definition of a security system ensuring confidentiality, integrity and availability of data on the basis of the functional service requirements and taking into account the existing level of security implemented in each country.

The objective is to select, among different options and on the basis of an *option analysis*, an appropriate, effective and reliable security system to be integrated in the system architecture.

To meet the functional requirements, the eHealth DSI system shall provide necessary security measures and adequate assurance. The required level of security cannot be reached by adding some security functions ex-post; security must instead be considered during the whole life cycle of the system.

This document wants to define both the security context/scenario and the security items which must be effective for the whole deliverable. Anyway it is accepted that Section I (Security Policies), which has to be self-comprehensive, can contain the "repetition" of some terms. This repetition can be done using different words, but the safeguard of the meaning given here must be assured.

2.2 Glossary & Abbreviations

The glossary and the abbreviations used in this document are explained in the [eHealth DSI Glossary].

3 Assumptions & Guidelines

3.1 Security View

3.1.1 Objectives prioritization

The main objectives of computer security, which follow the ISO/IEC 27002 indications, are:

- **Authenticity:** the identity of an actor has been proven as true;
- **Confidentiality**: information is accessible only to authorized users/[actors];
- **Integrity**: accuracy and completeness of information and processing methods;
- **Availability**: authorized users have access to information and associated assets when required;
- **Accountability/Non Repudiation (Liability):** each communication and each data transaction can be tracked back to a certain originator in a traceable chain of activities.

These objectives can be further divided and applied to Actors which leads to derived security objectives. The most relevant derived security objectives for eHealth DSI are:

- Entity (NCP/HP) Authenticity: an actor is the one he/she claims to be;
- Originator Authenticity: the source of data is as claimed;
- Access Control: access to information is restricted to authorised actors/entities;
- Non-repudiation of origin: the data Originator cannot deny having the data;
- Non-repudiation of delivery: the data Consumer cannot deny having received the data.

Taking into account the *business-objectives* (namely the transfer of health-care documents between two health-care organizations operating in two different countries in a way that the Consumer is able to grasp the same “clinical meaning” as expected by the Originator) and *IT-objectives* (as they are declared in the Functional Requirements), the security views are:

- **Integrity** and **Confidentiality** (and the derived objectives of entity authenticity, originator authenticity, and access control) are the most important security objectives as they are closely related to patient safety and to the respect of legal requirements (privacy) and massively influence the acceptance of eHealth DSI by physicians and Patients.
- **Accountability/Non Repudiation (liability)** is important for user acceptance. Due to the trust brokering role of NCPs and the independence of physicians in deciding on their use of provided information, the liability technical aspect, in eHealth DSI, is only an issue in NCP-to-NCP communication.
- **Availability** is important for user acceptance. Availability is a general non-functional requirement of the eHealth DSI system as a whole.

This leads to the conclusion that integrity of medical data and certain administrative data have a *high* (see ref. in par. 5.1-Data classification) protection demand. The confidentiality of patient data has the same *high* protection demand, such as the liability (non- repudiation), and the availability of eHealth DSI managed data have a *moderate* protection demand.

REMARKS:
a) it must be taken into account that the confidentiality objective is influenced by the requirement that NCP has to carry out a semantic translation so, consequently, it must operate on non-encrypted clinical data and thus be under control of a natural or legal person legally authorised to process medical data.

b) in order that the Consumer (HP) is able to use the received clinical data (the data submitted to the semantic translation) for decision-making on the Patient's health, it is necessary that the received document provides the Consumer -from the integrity point of view- with the same or higher integrity assurance as the original sent document.
As there is no forecast to submit the eHealth DSI to a formal security evaluation, then the Consumer will use the received document only for decision-support.

3.1.2 Indications for choice of security measures

Given that eHealth DSI deals with sensitive healthcare data, it should evaluate the use of either "detection measures" or "preventive measures". These measures (control) have different impact on operational abilities and productivity.
In eHealth DSI, to mediate between the needs of HPs and data Subjects (patients) rights, preventive measures are to be preferred.

3.2 Risk Analysis

Making reference to the ISO/IEC TR 13335-3 (ISO/IEC 27005) guidance, it has therefore been decided to apply a "**combined** approach" to risk analysis.
In particular in this document, at a higher level, it has been decided to apply a Risk Analysis "**informal** approach" - performed by skilled security people - to evaluate the risk of eHealth DSI project and to define the eHealth DSI security requirements.
It has also been decided to apply a Risk Analysis "**baseline** approach" (ref. to vulnerabilities and threats ISO/IEC 27005 catalogue), to evaluate the risk of each Security Service proposed, in order to select the best solution and also, if applicable, to identify specific security constraints on the selected solution.

4 Overall picture & logical scheme

This chapter is going to give a general view of the security in the eHealth DSI and the introducing concepts will be detailed in the next chapters.

4.1 Overall picture

Figure 4.1 illustrates a conceptual diagram of the eHealth DSI infrastructure for exchanging medical patient data between European countries.

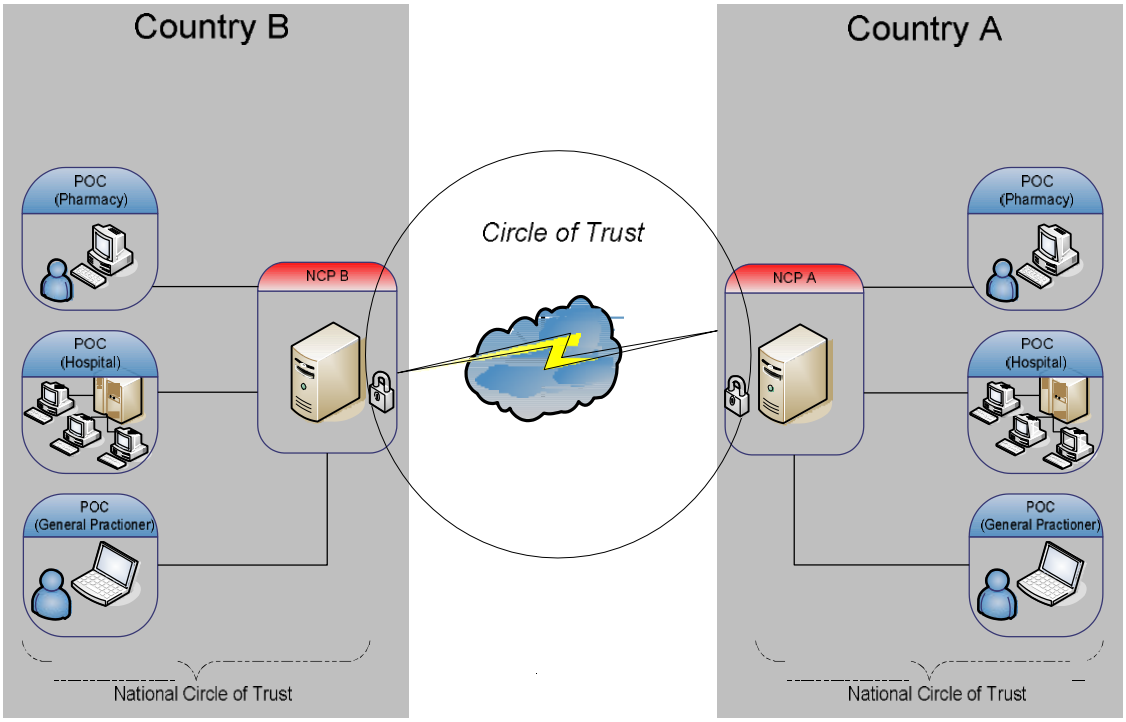


Figure 4.1: Overall picture of the eHealth DSI infrastructure

The core paradigm of the eHealth DSI is not to directly connect physicians but to connect the national infrastructures of a patient's home country and the country where a patient currently receives medical services. Within the eHealth DSI the patients' home country is referred to as country 'A' and the country where the patient gets medical treatment is referred to as country 'B':

- Country A is the Country of Affiliation (CoA), this means that country A is legally the exclusive entity, which is responsible for appropriately storing, archiving and documenting any required health information of a patient within its existing national infrastructure. For the eHealth DSI, it is assumed that all attributes and credentials that could be used to identify and authenticate the patient are issued by country A.
- Country B is the country where the Point of Care (PoC) is located that provides healthcare to a patient from country A. For the eHealth DSI it is assumed that the HP and HCPO that treat the patient can only be unequivocally authenticated by the competent authorities of country B.

The PoC could be a hospital, an individual practitioner, a pharmacy or any other point of the health care system of any country, participating in the eHealth DSI system. Each communication and each data transaction can be tracked back.

Figure 4.1 focuses on a business point of view that relies on the use of health data retrieved from a Country A by a HP located in Country B. Therefore existing national ePrescription and PS services of country A which persistently maintain the patient's data are not shown.

The Trust relationships

A legal framework for the eHealth DSI admits the country's infrastructures. Since all participants must agree to sign a predefined contract, they establish a trust relationship. The signing of the contract and all the related implications can be assumed as the legal level of the "eHealth DSI Circle of Trust" (CoT). Within this circle of trust each country is represented by a "National Contact Point (NCP)". The technical level of the eHealth DSI CoT will then be the configuration of NCP endpoints, the NCP access control and digital certificates exchange, that allow inbound and outbound communication for the configured NCPs.

Inside country, contractual arrangements will be established, aligned as required on the eHealth DSI framework contract. These national Circles of Trust must meet all the local and EU legal requirements on topics e.g. patient consent, data security, patient confidentiality, HP liability, etc. Routing all eHealth DSI communication through a country's NCP thus ensures that all actions taken within the country are compliant with the eHealth DSI legal framework.

To conclude, the eHealth DSI system leads up to building cascaded circles of trust:

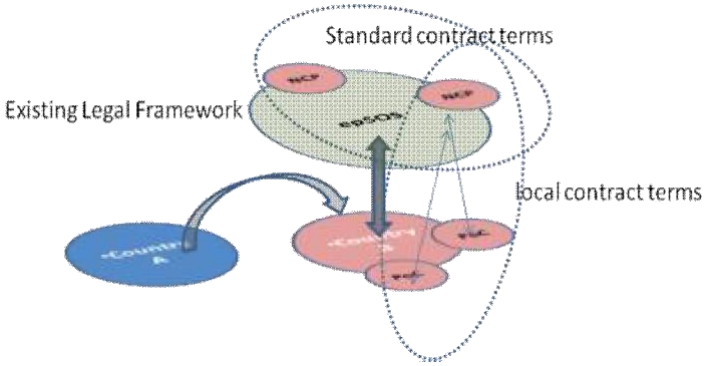


Figure 4.2: eHealth DSI Trusted Domain

4.2 eHealth DSI Security challenges

A security framework needs to consider user authentication and authorization as well as to use encryption to protect communication over non-secure networks. Even more, the integrity of medical data and its assignment to a certain patient have to be protected. [see section 3.1].

4.2.1 Security challenges

While these requirements apply to every eHealth infrastructure, the Circle of Trust topology of the eHealth DSI, its complete decoupling of data users and data providers, and the integration of existing infrastructures lead to some eHealth DSI-specific challenges:

- [a] Security objects are issued and consumed by different countries. The consumer (HP) has no influence on how a security object is issued. This demands a complete decoupling of the respective services and puts strong emphasis on a secure exchange of authentic, standardized security objects.
- [b] Safeguards are applied by one national infrastructure and must be verified by another infrastructure. As NCPs are the only common known instances they are the only entities that can be used for this. Therefore end-

to-end security is only available among NCPs. As a consequence NCPs act as “trust mediators” and require for specific means to broker security down to the “real” ends of secure business end-to-end communication which are the PoC in country B and the data providing systems in country A.

- [c] Country B needs access control meant to protect its HPs from accidentally accessing data in an illegal way, in accordance to its national legislation. Country A, by means of safeguard mechanisms, has to protect the privacy of its citizens and to ensure the required integrity and confidentiality of its internally managed data objects.
- [d] Acting entities are unknown outside their national infrastructure: Country A depends on country B to identify and authenticate the person that requests access to data of country A. Country B depends on country A to provide the means for patient identification/authentication and for identifying/discovering the medical data that will be used by the HP in country B.
- [e] In the existing eHDSI model, patient identification is performed by country B (challenge [d]): the HP enters patient traits at the NCP-B portal, country A resolves the patient identity via the XCPD handshake. The security of this process rests entirely on the HP authentication and TRC assertion mechanisms defined in the SAML Profile.
  CP090 introduces an optional alternative where the patient actively presents a verified PID credential from their EUDI Wallet app. This credential is:
  - Issued by a member state PID Issuer operating under the eIDAS 2.0 framework — not by country B's national IdP.
  - Governed by an EU-level trust anchor (the EU Trusted List of EUDI Wallet issuers) — not by the eHDSI NSL.
  - Transmitted directly from the patient's mobile device to the NCP-B over a public internet channel — not over the TESTA/sTESTA backbone.
  - Subject to patient-controlled selective disclosure and explicit in-wallet consent — not mediated by the HP.

  This creates a new trust brokerage requirement: NCP-B must be able to validate a credential issued within the EUDI Wallet ecosystem and translate the trust it represents into the eHDSI security token model (TRC assertion). The NCP continues to act as the sole trust mediator, but its trust inputs now include a second external trust domain alongside the national IdP

4.2.2 Security core concepts

In order to deal with these challenges, eHealth DSI security builds upon the following core concepts:

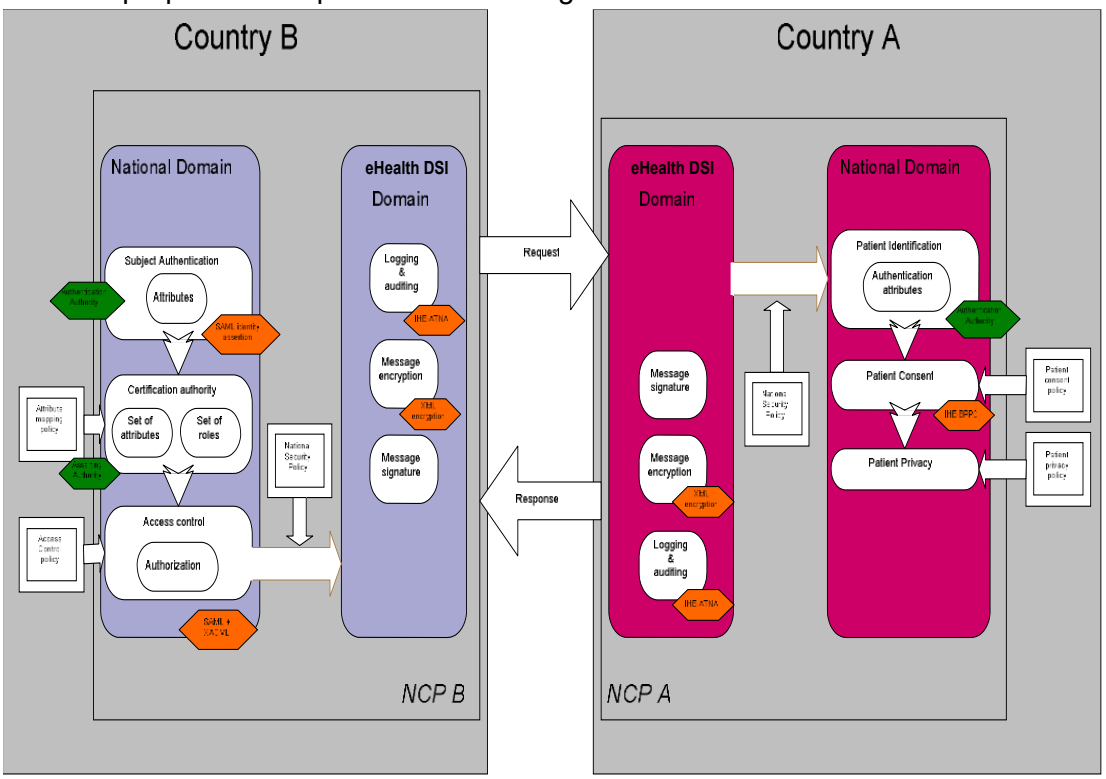
- [I] Definition of dedicated security services as business level independent profiles.
- [II] Use of security contexts: prior to business transactions, security services set up a secure session context which allows the decoupling of security and business related issues.
- [III] Use of a security token for the transmission of security related information and for holding the secure session context.
- [IV] Separation of policy concerns by considering dedicated policies for national legislation, patient consenting, and patient privacy statements.
- [V] NCPs are the only entities that are known within both the eHealth DSI domain and their respective national domains. Trust brokerage among eHealth DSI and national domains is completely encapsulated within NCPs.
- [VI] The EUDI Wallet architecture enables a patient to present a

cryptographically signed, member-state-issued PID credential directly to the NCP-B. The patient retains full control: the wallet app displays the requested claims before any data is transmitted, and the patient must actively approve each presentation. This mechanism:

- Extends concept [III] - the security token set - by introducing a VP Token as an optional input alongside the existing HP Identity Assertion and TRC Assertion.
- Extends concept [IV] - separation of policy concerns - by adding a third policy layer: the EU Trusted List governing PID issuer trust, alongside national legislation and patient consent policies.
- Extends concept [V] - NCP as trust mediator - by requiring the NCP-B to bridge between the EUDI Wallet trust domain and the eHDSI security token model. The NCP-B validates the VP Token against the EU Trusted List and maps verified PID claims into a standard TRC Assertion, ensuring NCP-A continues to operate against a familiar, eHDSI-standard security object.
-
- Critically, concept [VI] preserves the invariant of concept [V]: NCP-A sees no change. It continues to receive and validate a TRC Assertion signed by NCP-B. The EUDI Wallet provenance is encoded as supplementary TRC attributes (patient-id-source, pid-issuer-country) but does not alter the TRC structure or the NCP-to-NCP protocol.

4.3 Logical scheme

The figure below provides a logical view of the eHealth DSI project and reflects the solutions proposed to cope with the challenges that were sketched above



This logical scheme is based on a generic business process for a HP to get a medical document.

The patient has to be identified in country B by means of any solutions that country A provides (e. g. by obtaining patient demographics or unique identifiers in an organizational procedure in country B for “eHealth DSI patients”). As the identity

of a patient is verified, it means that authentication attributes needed in country B are provided by an authentication authority in country A. For emergency access ("breaking glass scenario"), a special procedure is to be invoked. A HP requesting an "override" access will specifically and doubtlessly state his intention and reason for the emergency data access request.

This step faces challenges [a] - *Standardize security objects* - and [d] - *Unknown actors* - with respect to the identity/authenticity and consent of the patient. Depending on the required accuracy of patient identification and the kind of identifier used, an exchange of identity related data between country B and A is needed because only country A "knows" the patient. The same applies for the HP: at a high level, in order to apply the policies (e.g. NCP of country A leads to communicate not only the identity information but also the role of the HP), there is a need to assess the identity of subjects (HP or HCPO), i.e. it requires their authentication.

Logging and Auditing are essential features of systems which are pr*ovided by the different serv*ices such as level agreements, contractual obligations or legal requirements. Logging is a general mechanism which is based on specific recordings of configurable aspects regarding the activity of a system in sequential order. Usually a system will offer a large variety of logging mechanisms, like *security logs (records all attempts to access a system; successful as well as failed attempts)*, activity logs, error logs, etc. In case of an emergency, access may be gained even if the patient had not explicitly authorized the doctor to do this. Logging and auditing mechanisms occur in both NCPs involved in an eHealth DSI UC. Logging and auditing mechanisms must take into account that an activity may require tracing from one NCP to another one (e.g. in case of abuse). They have not been represented on the scheme but audit trails should be also implemented at PoCs.

Request and response messages are based on standard protocols ([NCPeH Components Specification]). Data confidentiality and data integrity between NCPs is provided by cryptographic technologies, processes and operations. In order to solve challenge [b] - National safeguards - eHealth DSI security places NCPs in both circles of trust.
This allows them to mediate security services (e.g. confidentiality) between both circles. By doing so the NCP takes the role of a bearer, e.g. by confirming the authenticity of a data originator.

Security contexts may be established via either SOAP WS-Security SAML tokens or FHIR JWT tokens carrying equivalent claims, and that the same protection requirements apply to both flows.

5 Definition of elements and actors relevant for security issues

In this section the elements (data classes) and actors in the eHealth DSI are considered from a security point of view.

5.1 Data classification

A generalized data classes are introduced together with their protection requirements.
Each element in the eHealth DSI belongs to one of these data classes.

The following data classification is considered in eHealth DSI:

- **Healthcare-related Data**: Healthcare Data of a patient e-prescription or patient summary used for the medical treatment of a patient. According to the [Regulation (EU) 2016/679] the processing of medical data has to satisfy higher privacy requirements since they belong to the special categories of data (Article 9 Regulation (EU) 2016/679).
  Healthcare related data contain also:
  - data about the patient's consent;
  - log data which provide information about the access to healthcare related data in eHealth DSI.
- **Critical Meta Data**: Data needed to control the exchange of healthcare related data between NCPs and between NCPs and PoCs, respectively. Critical Meta Data include authentication, identification and administrative data to clearly identify patients, PoCs and HPs,
- **Non-critical personal data**: Personal data which do not belong to the special categories of data according to Article 9 Regulation (EU) 2016/679 and do not belong to the critical meta data.
- **Administrative Data**: They do not contain any personal data. They are used for the administration or configuration of technical components.

The data classes differ in the damage that could occur if the confidentiality, integrity, or availability are lost. The damage is categorised according to the following threats:

Threat	Healthcare-related Data	Critical Meta Data	Non-critical personal data	Administrative Data
Violations of laws, regulations, or contracts	Can have substantial consequences, for example violates national privacy laws or professional secrecy laws	Can have substantial consequences, for example violates national privacy laws or professional secrecy laws	Can have substantial consequences, for example national privacy laws	Have minor consequences
Impairment of privacy	Processing could have a seriously adverse effect on the social standing of the persons.	Processing could have a seriously adverse effect on the social standing of the persons.	Processing could have an adverse effect on the social standing of the persons.	No damage on privacy

Physical injury	Serious injury to an individual is possible. There is a danger to life and limb (e.g. a medical treatment based on modified and false health-care data may have serious consequences on the state of health of a person).	Serious injury to an individual is possible.	Does not appear possible.	Does not appear possible.
Negative internal or external effects	Considerable impairment of the reputation /trustworthiness can be expected.	Considerable impairment of the reputation / trustworthiness can be expected.	Only minimal impairment or only internal impairment of the reputation / trustworthiness is expected.	Only minimal impairment or only internal impairment of the reputation / trustworthiness of the organisation is expected.

Table 5.1: Impact dependent on threat and data class

The impacts of the damages on the confidentiality, integrity, availability, authenticity and non-repudiation of the data in data classes are qualified in terms of high, moderate, and low impact according to [FIPS 199]. The level for availability is set to low, since there are existing alternative processes (patients are treated already today), so that a medical treatment is also guaranteed without the eHealth DSI data.

Data class	Confidentiality	Integrity	Availability	Authenticity	Non-repudiation	Category
Healthcare-related Data	High	High	Low	High	High	patient identifiers and HP credentials
Critical Meta Data	High	High	Low	High	High	configuration
Non-critical personal data	Moderate	Moderate	Low	Moderate	Moderate	
Administrative Data	Low	Low	Low	Low	Low	

Table 5.2: impacts level

5.1.1 Classification of PID Claims During the Identification Transaction

PID claims extracted from a verified EUDI Wallet VP Token — given name, family name, date of birth, and personal administrative number — are patient identity data. During the brief window between VP Token receipt and XCPD query completion, these claims are classified as Critical Meta Data (see Table 5.1 and 5.2) and carry the corresponding protection requirements:

Data element	Confidentiality	Integrity	Availability	Authenticity	Non-repudiation
PID claims (in-memory, during XCPD transaction)	High	High	Low	High	High
VP Token (raw, in-memory)	High	High	Low	High	High
EUDI presentation session ID (audit log)	Moderate	High	Low	High	Moderate
PID provenance attributes in TRC (patient-id-source, pid-issuer-country)	Moderate	High	Low	High	High

5.1.2 EPHEMERAL HANDLING REQUIREMENT

PID claims and the raw VP Token have High confidentiality and authenticity requirements but a Low availability requirement, consistent with the existing Critical Meta Data classification. However, they differ from other Critical Meta Data in one essential respect: they MUST be treated as ephemeral. Specifically:

- PID claims MUST be held exclusively in process memory and MUST NOT be written to any persistent store (database, cache, log file, disk).
- The raw VP Token MUST be discarded from memory immediately after the six-step validation sequence completes, whether validation succeeds or fails.
- PID claims MUST be discarded from memory immediately after the XCPD query result has been received and the patient identifier resolved.
- The maximum permissible in-memory lifetime of PID claims is the duration of a single XCPD transaction, bounded above by the 5-minute session timeout.

5.2 Actors

The following actors (or entities) are considered in eHealth DSI:

- **Patient**: any natural person who receives or wishes to receive health care in a country.
- **Healthcare Professional (HP)**: see [eHealth DSI Glossary]. Furthermore, a HP must be under national law or rules established by national competent authorities to the obligation of professional secrecy or by another person also subject to an equivalent obligation of secrecy.
- **National Contact Point (NCP)**: see [eHealth DSI Glossary] (A legal entity representing a country within eHealth DSI, assuming legal duties towards country partners and its own network of national gateways: it acts in a bidirectional way transmitting in-outbound messages between national IT infrastructures and NCPs from other country). A NCP processes medical data in order to achieve interoperability.

- **Technical Staff**: Any person or organisation participating in the eHealth DSI processes not involved in the medical treatment of a patient such as
    - System administrator – in charge of the central organisation that maintain the system
    - Local system administrator – in charge of the local, national organisation that maintain the system locally within a country.
    - System operators.
- **Data Security Officer**: The data security officer of the organization which processes healthcare-related data. For example, he/she can check the log data if there is a reasonable suspicion and the patient agreed.
- **Auditor**: Any person who satisfies the eHealth DSI auditor requirements and who audits eHealth DSI.
- **HealthCare Provider Organisation (HCPO)**: see [eHealth DSI Glossary].

5.2.1 AMENDMENT TO THE PATIENT ACTOR

The existing Patient actor is defined as a passive entity receiving healthcare. CP090 introduces an optional active dimension: when a patient uses their EUDI Wallet to present PID credentials to an NCP-B, they temporarily assume the role of an active participant in the eHDSI security protocol. In this role the patient:

- Controls which PID claims are presented (selective disclosure via the wallet consent prompt).
- Actively approves or denies each presentation request.
- Holds cryptographic control over their PID credential via the wallet app.

This active role does not alter the patient's legal status within eHDSI. Country A remains the exclusive responsible entity for patient data. The patient's active participation is limited to the identity assertion phase and does not grant the patient direct access to the eHDSI infrastructure.

5.2.2 NEW ACTOR: EUDI WALLET PID ISSUER

A EUDI Wallet PID Issuer is a member state authority designated under Article 45f of Regulation (EU) 2024/1183 to issue Person Identification Data credentials to citizens' EUDI Wallet apps. PID Issuers are trusted third parties operating outside the eHDSI Circle of Trust but within the EU Trusted List trust framework.

PID Issuers are passive actors in the eHDSI context: they issue credentials offline to patients' wallets and are not contacted at runtime during eHDSI transactions. Their trust contribution is mediated by the EU Trusted List, which NCP-B queries to validate the issuer certificate chain of a presented VP Token.

5.2.3 NEW ACTOR: NCP-B EUDI RELYING PARTY

When an NCP-B deployment activates the EUDI Wallet channel, it assumes an additional actor role within the eIDAS 2.0 ecosystem: EUDI Wallet Relying Party (RP). In this role the NCP-B:

- Registers with the national competent authority under Article 5b of Regulation (EU) 2024/1183.
- Holds an RP Registration Certificate used to sign OpenID4VP presentation requests.
- Is displayed to the patient in the wallet consent prompt with its registered name and purpose.
- Is legally accountable for the PID claims it requests and the use it makes of them.

The NCP-B EUDI RP role is entirely additional to and separate from the existing NCP-B role within eHDSI. It does not alter the NCP-B's obligations toward NCP-A or the eHDSI Circle of Trust.

5.3 Actors from a security point of view

The actors (active and passive entities) are characterized from a security point of view in the following aspects:

- **Access rights**: describes the data classes an actor is allowed to access.
- **Authentication level**: describes the strength of the authentication means an actor must use to access eHealth DSI. The authentication means can be organizational (for example passport, health card) or technical (for example password, cryptographic certificate).

Patients (passive entities) have the right to know all about their personal data processed in the eHealth DSI. Access can be carried out either technically by providing patient-centric interfaces or organizationally, e.g. requesting a HP or a data security officer. Organizational measures (e.g. passport, health card) can be used for the identification and authentication of a patient against a HP.

Actor (active entity)	Access Rights	Authentication level
Healthcare Professional	Healthcare-related data, Critical Meta Data, Non-critical personal data	Organizational against patient (e.g. health professional card), Technical against systems of PoC (e.g. password, smartcard)
National Contact Point	Healthcare-related data, Critical Meta Data, Non-critical personal data, Administrative data	Technical against NCP, PoC (must use strong authentication mechanism, e.g. cryptographic certificates)
Technical Staff	Administrative data	Technical (e.g. password, smartcard)
Auditor	Non-critical personal data, Administrative data	Technical against systems of PoC, NCP (e.g. password, smartcard)
HCPO	Healthcare-related data (only if HP or NCP, otherwise no access) Critical Meta Data Non-critical personal data Administrative Data	Technical against NCP
Data Security Officer	Healthcare-related data (except of medical information), Non-critical personal data	Technical against systems of PoC, NCP (e.g. password, smartcard)
Patient (active role via EUDI Wallet)	No direct access to eHDSI infrastructure. Access is limited to: selective disclosure of own PID claims via wallet consent prompt.	Authenticated by the PID Issuer at wallet onboarding (national LoA High, per eIDAS 2.0 Art. 24). At runtime: possession of the wallet device and biometric/PIN unlock serves as implicit authentication.
EUDI Wallet PID Issuer	No access to eHDSI infrastructure. Issues PID credentials to patients offline. Trust contribution mediated by EU Trusted List.	Authenticated by EU Trusted List certificate chain. Validated by NCP-B at VP Token validation time (not at runtime interaction).
NCP-B as EUDI Relying Party	Access rights: Critical Meta Data (PID claims) — in-memory only, ephemeral (see section 5.1.2). No persistent access to patient PID data.	Authenticated to patient wallet by RP Registration Certificate (eIDAS 2.0 Art. 5b), displayed in wallet consent prompt. Key stored in HSM (mandatory in production).

Table 5.3: Actors Access Rights and Auth. level

6 References

6.1 Normative References

[ISO/IEC TR 13335] ISO/IEC 13335:2005 – Part 1 to 5: Information technology – Guideline for the management of IT Security 2005.

[FIPS 199] FIPS 199: Federal information Processing Standards Publication 199, Standards for Security Categorization of Federal Information and Information Systems. December 2003.